ONE-PAGE BRIEF

Post-quantum cryptography review: orchard @ 616a669df8c9

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/orchard, commit `616a669df8c9` · Reviewed: 2026-11-06 13:43 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **0** High **7** Medium
4 Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-18430	**Quantum-vulnerable Pedersen commitment: threshold signing and MPC protocols (14 file(s))** preliminary What to do: Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the signature scheme; record which keys...
Medium QSI-2026-18434	**Quantum-vulnerable RedDSA: transaction and message signing (1 file(s))** preliminary What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...
Medium QSI-2026-18431	**Quantum-vulnerable Halo 2 (IPA): role not determined (16 file(s))** preliminary What to do: Classify each usage, record data lifetimes, and plan migration to a post-quantum algorithm; introduce an abstraction layer for...
Medium QSI-2026-18432	**Quantum-vulnerable RedDSA: role not determined (1 file(s))** preliminary What to do: Classify each usage, record data lifetimes, and plan migration to a post-quantum algorithm; introduce an abstraction layer for...

7 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium threshold signing and MPC protocols	Pedersen commitment	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the...
Medium transaction and message signing	RedDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium authentication and identity (certificates, tokens, device attestation)	RedDSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	Halo 2 (IPA), Sinsemilla, RedDSA	Classify each usage, record data lifetimes, and plan migration to a post-quantum algorithm; introduce an...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 5; unlikely to apply to this build: 1 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 4.

Static review of source code and manifests; files analysed: 49. No requests were sent to the owner's systems.

Full report, content SHA-256: `7ead53f1d66ac34465839bd4b04fd11233287da68ec82116c9dd45379088c965`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.